

M 103: Burp (20 pts)

What You Need for This Project

- A computer with the Genymotion android emulator, which you prepared in a previous project.

Purpose

To get Genymotion and Burp working, so you can perform man-in-the-middle traffic interception, to detect SSL certificate validation errors.

Use Android 5.1

Android 8 no longer allows
user-defined TLS certificates.

Installing Burp

Burp is a very popular proxy, enabling you to view and alter network traffic.

In a Web browser, go to <https://portswigger.net/burp/communitydownload>

Download the Community Edition and install it.

Ubuntu Users

If you are using Ubuntu, execute these commands:

```
cd
cd Downloads
ls -l
```

You should see the name of the downloaded file, which should be something like **burpsuite_free_v1.6.01.jar**. Use that name in the commands below:

```
cd
cd Downloads
sudo mkdir /opt/burp
sudo mv burpsuite_free_v1.6.01.jar /opt/burp
cd /opt/burp
sudo touch burp
sudo chmod 777 burp
sudo echo "java -jar burpsuite_free_v1.6.01.jar" > burp
./burp
```

Warning

If you run Burp in Kali, it seems not to properly export the certificate and Chrome on Android refuses to accept it. It can be imported but Chrome gives an error when opening secure pages anyway.

We succeeded by running Burp directly on the host system instead (Mac OS).

Starting Burp

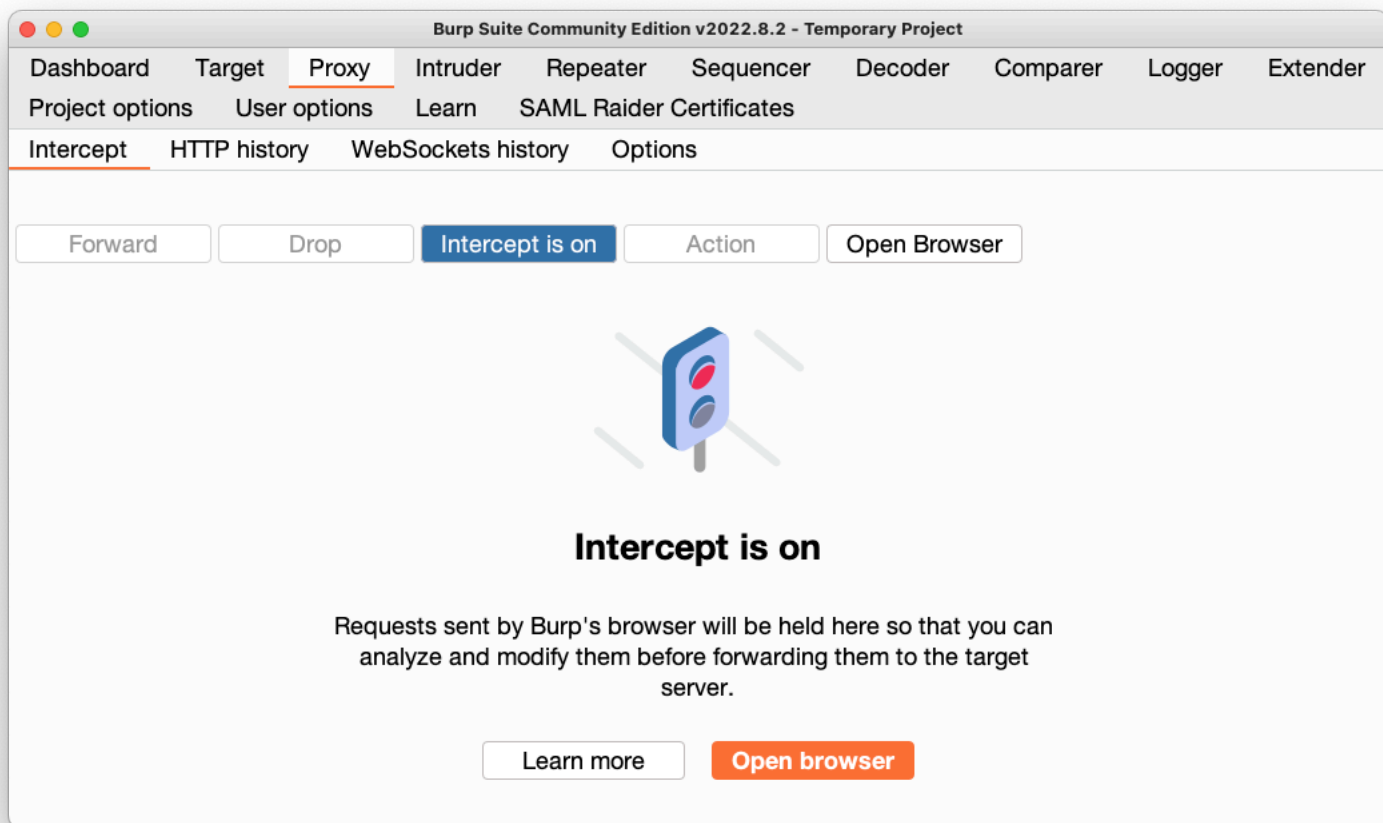
When Burp starts, the first window asks you to create a project. Accept the default option of "Temporary project" and click **Next**.

In the next page, click the **Start Burp** button.

The main Burp window opens, as shown below.

Click the **Proxy** tab. Click the **Intercept** sub-tab.

The third button says "**Intercept is on**", as shown below.

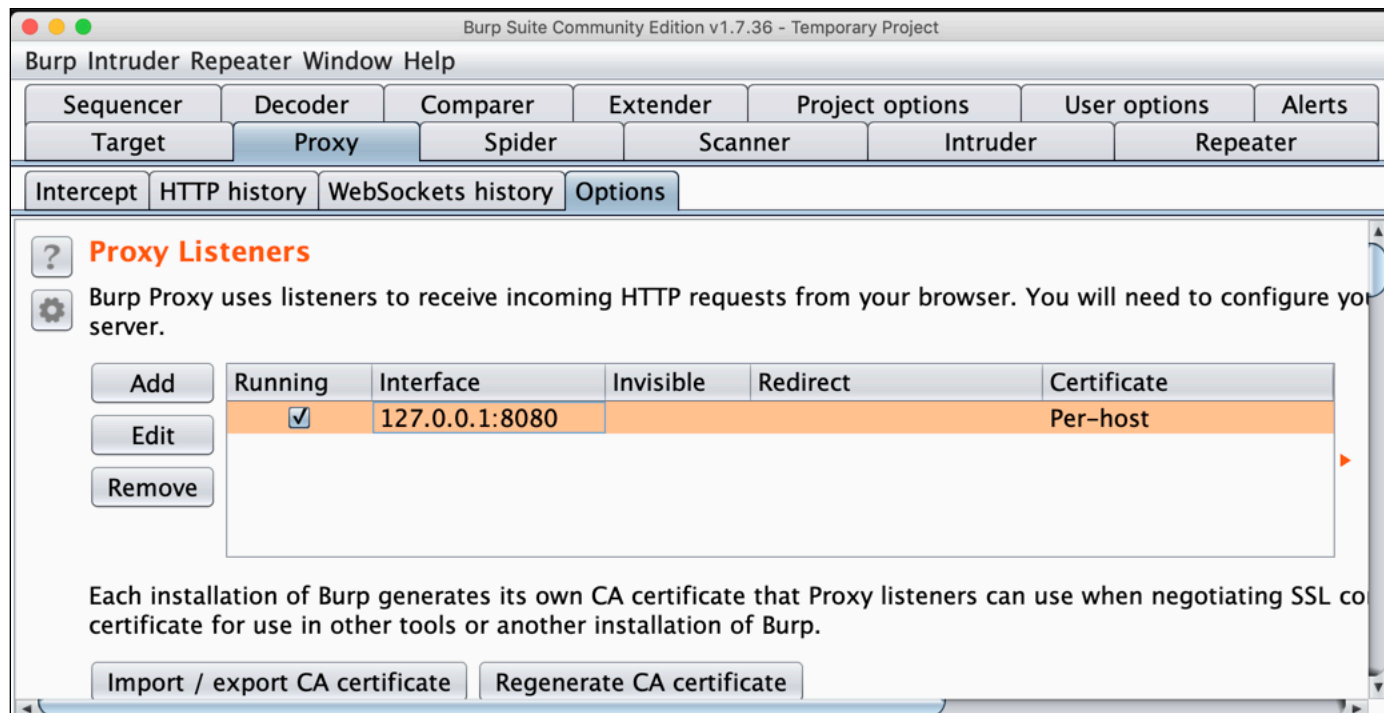


Configuring Burp

In Burp, click the "Intercept is on" button. It changes to "Intercept is off".

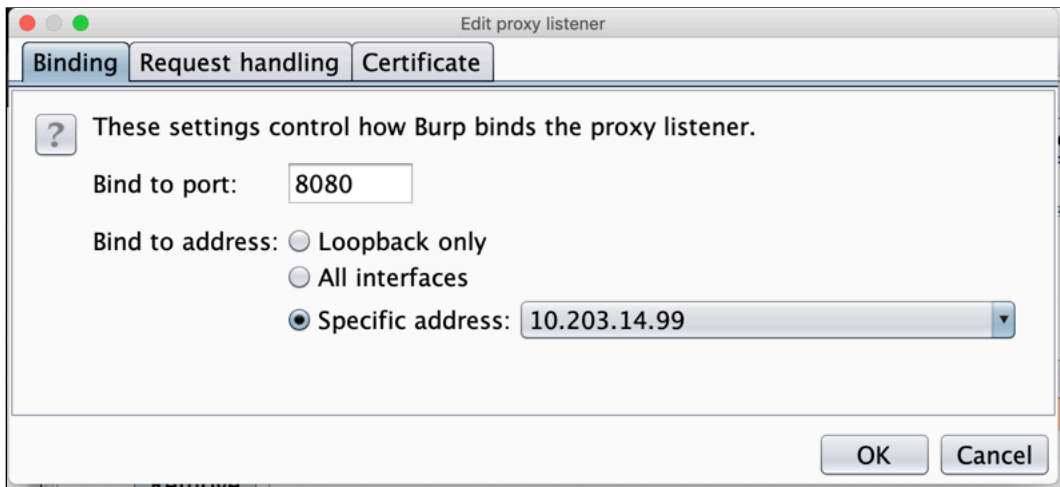
On the **Proxy** tab, click the **Options** sub-tab.

In the central box, click the Interface address to highlight it, as shown below.



On the left side, click the **Edit** button.

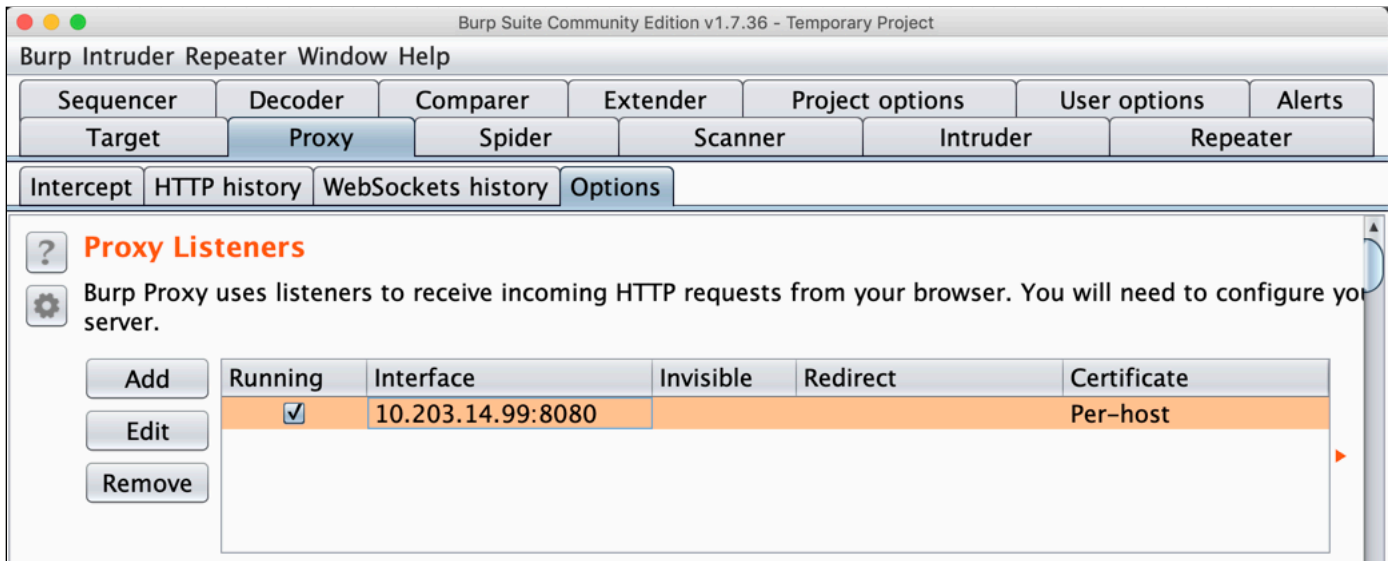
In the "Edit proxy listener" box, click the "Specific address" button, and select your computer's IP address that is used to connect to the Internet, as shown below.



Click **OK**.

Burp shows a proxy listener on your IP address and port 8080, as shown below.

Make a note of this address--you will need it below.

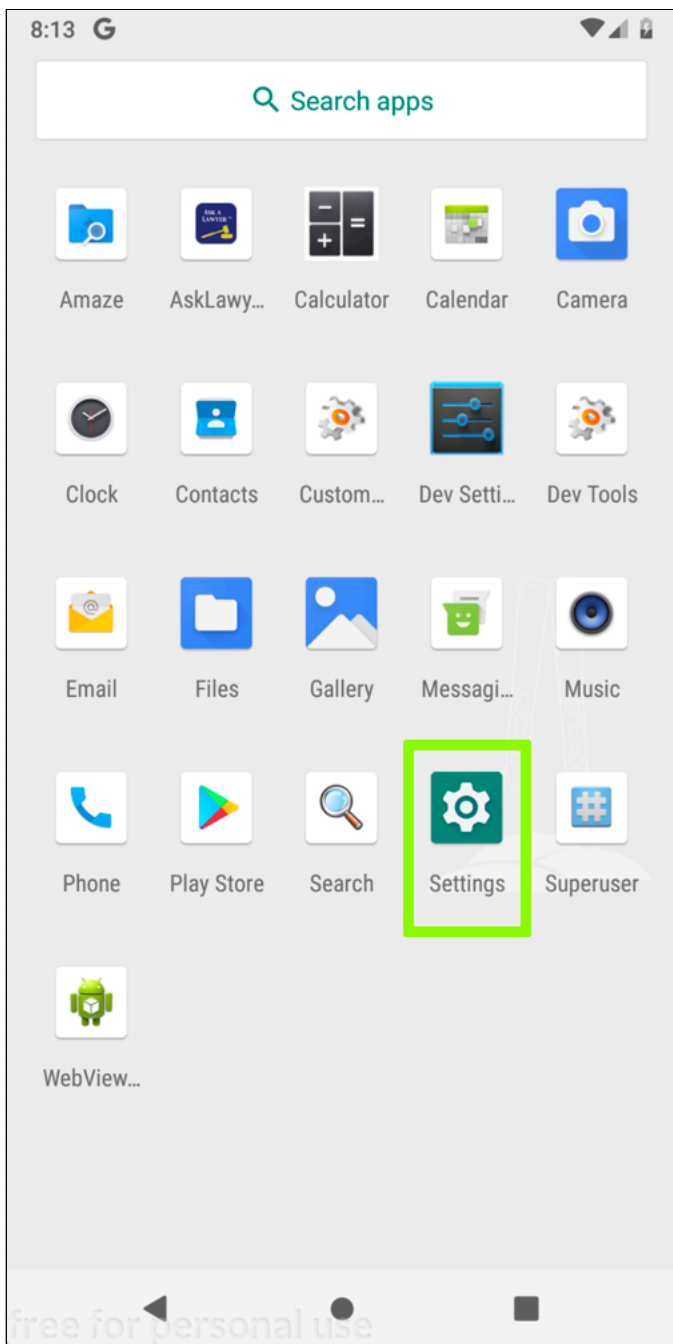


Adjusting Android Networking to Use the Burp Proxy

Launch your Genymotion Android device.

From the Android home screen, click and drag up to show all apps.

Click **Settings**, which is outlined in green in the image below.



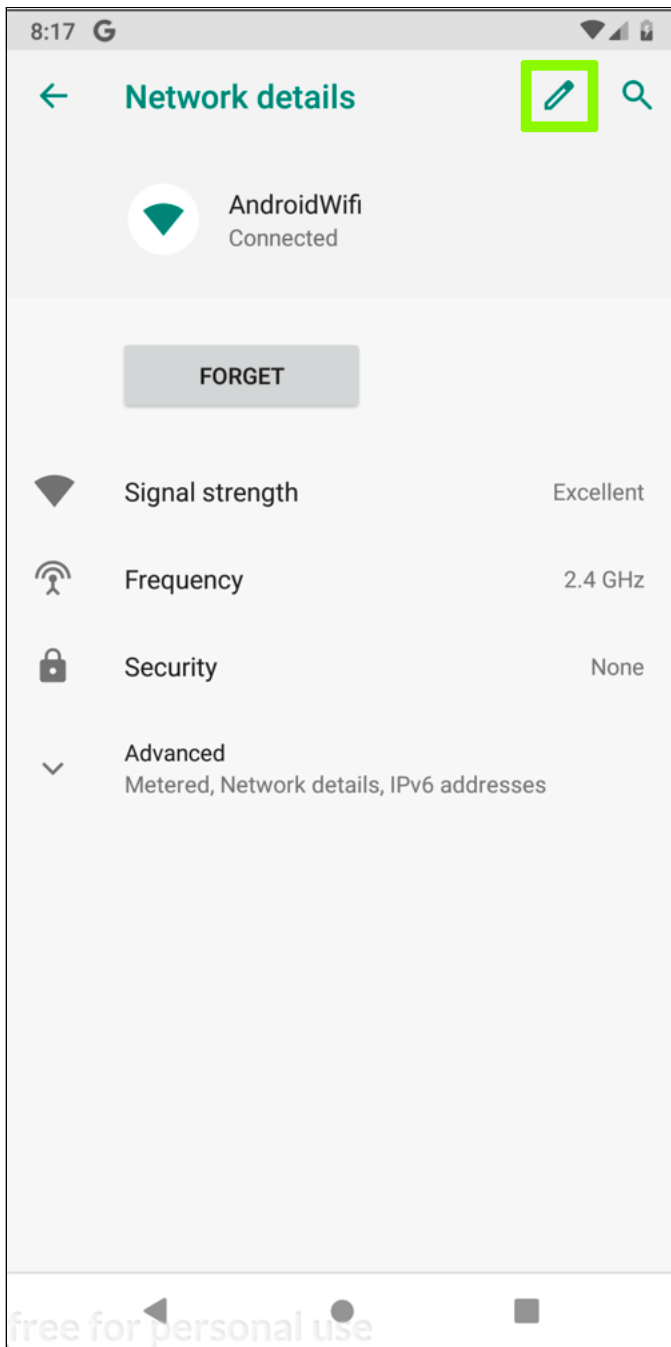
In Settings, click "**Network & internet**".

Click **Wi-Fi**.

Click **AndroidWiFi**.

Click **Advanced**.

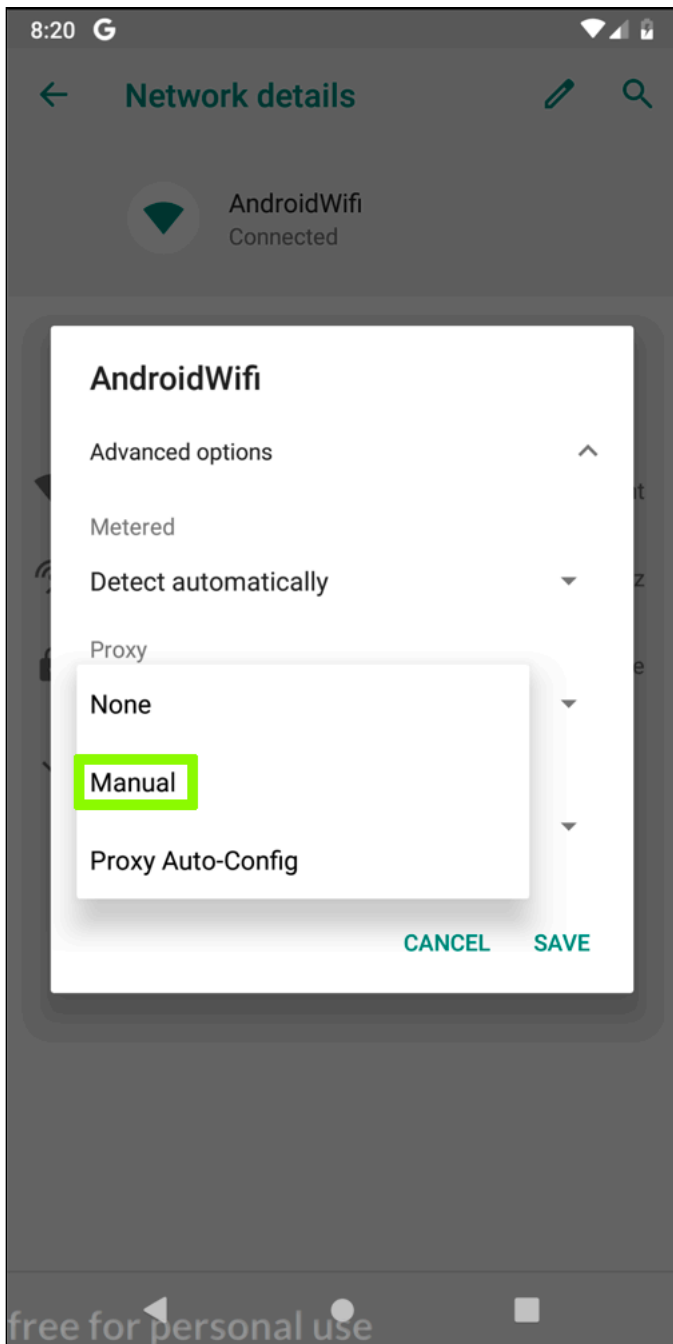
In the "Network details" screen, at the top right, click the **Pencil** icon, outlined in green in the image below.



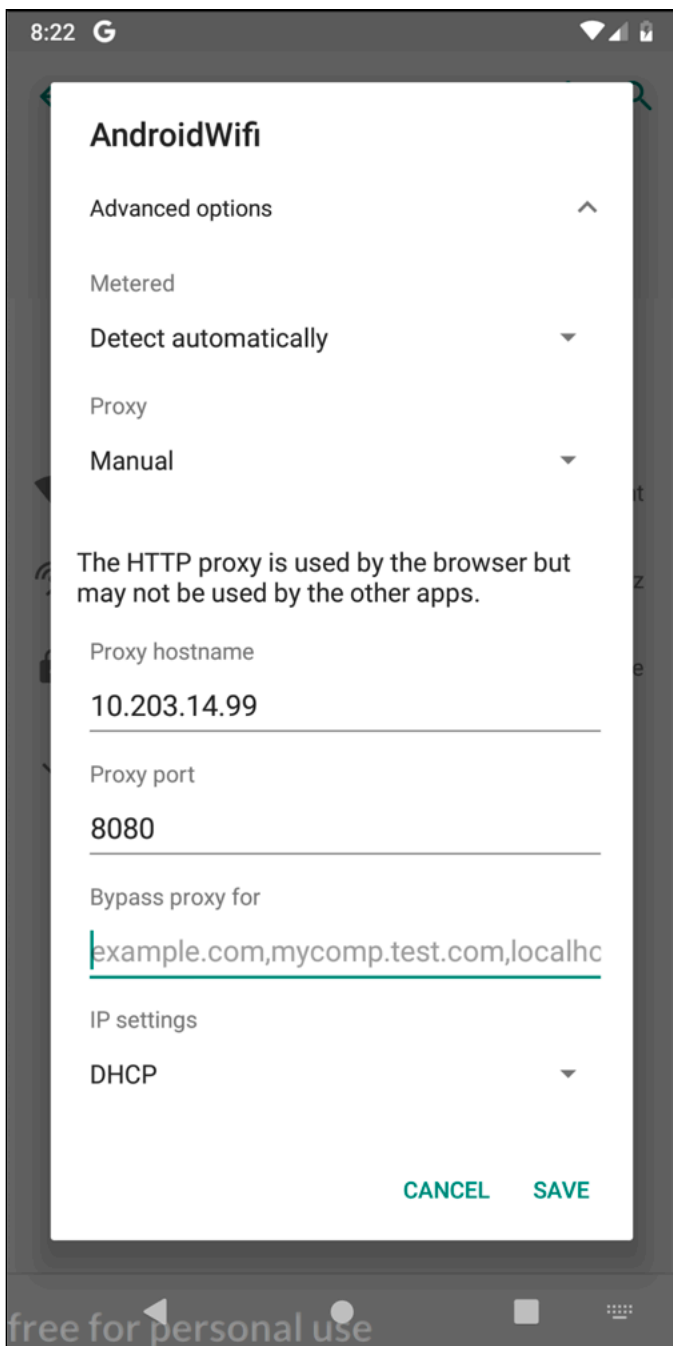
In the "AndroidWifi" box, in the "Advanced options" row, click the down-arrow.

In the "Proxy" field, click the down-arrow.

Click **Manual**, which is outlined in green in the image below.



Enter the IP address and port number of the Burp proxy listener, as shown below.

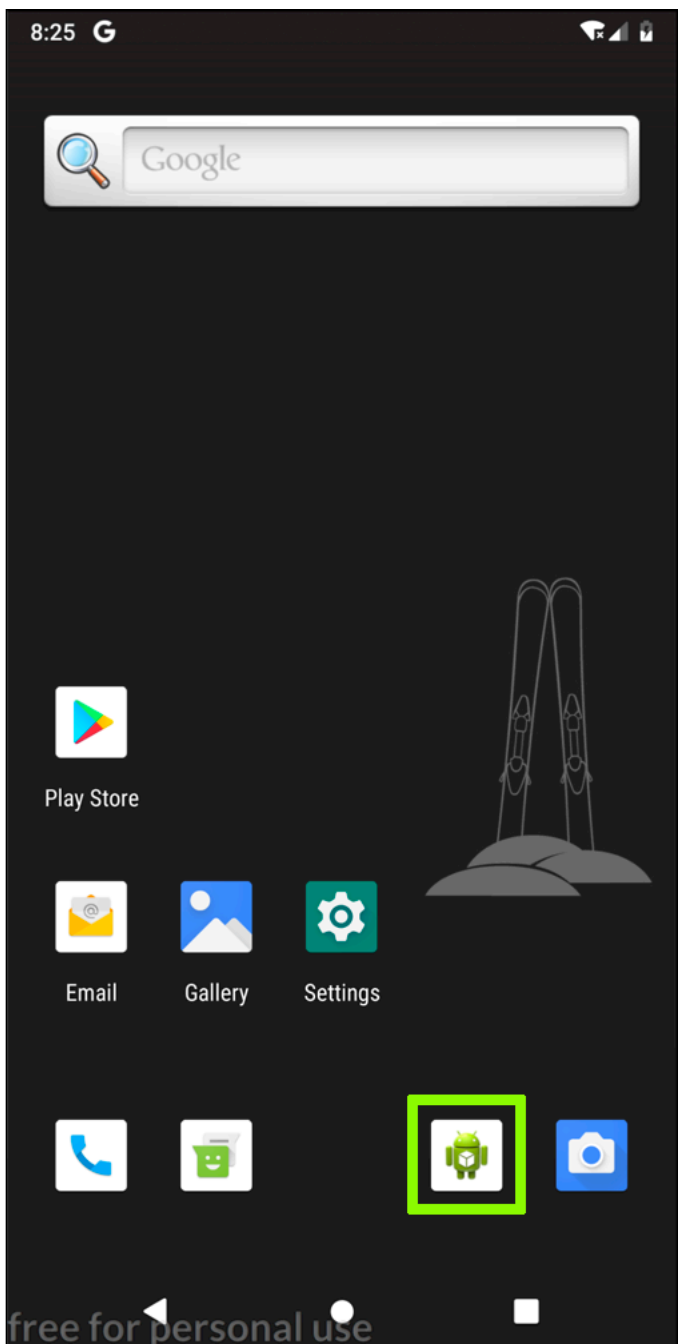


On your Android device, click **SAVE**.

At the bottom center of the device, click the round **Home** button.

Testing the Proxy

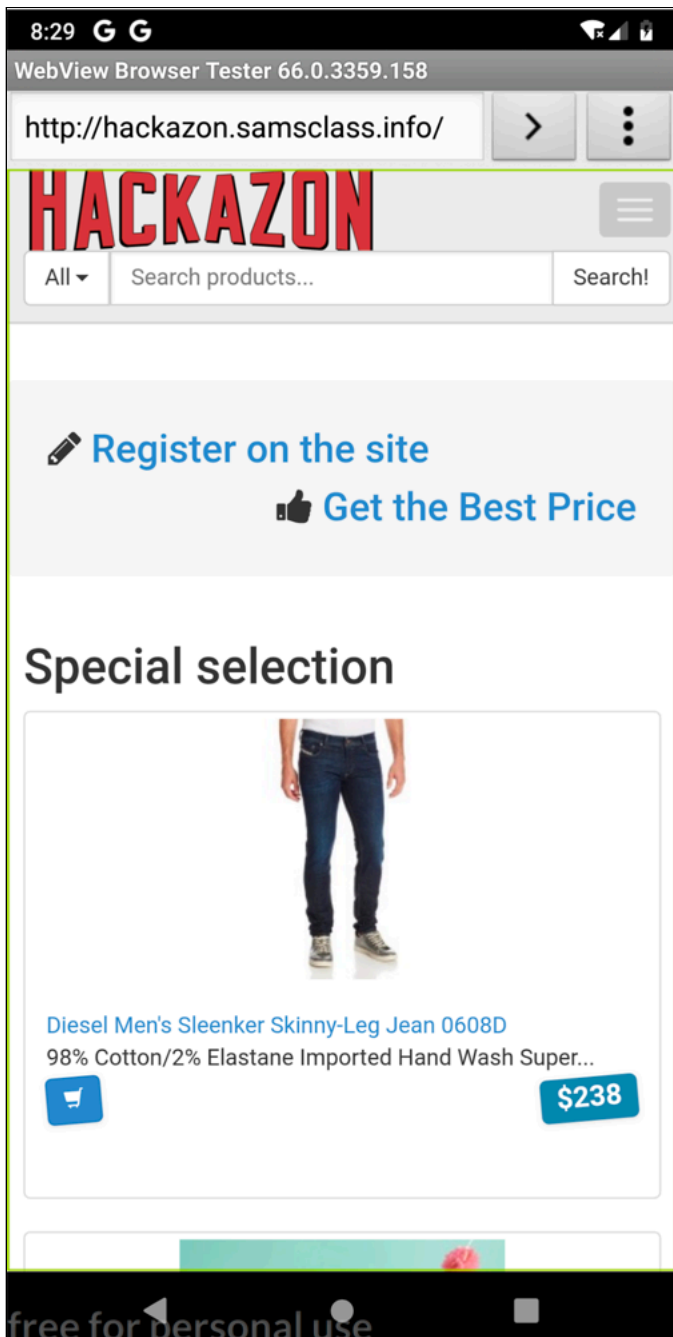
From the Android home page, on the lower right, click the **Browser**, outlined in green in the image below.



In the Browser, and go to

hackazon.samsclass.info

A "Hackazon" shopping site opens, as shown below.



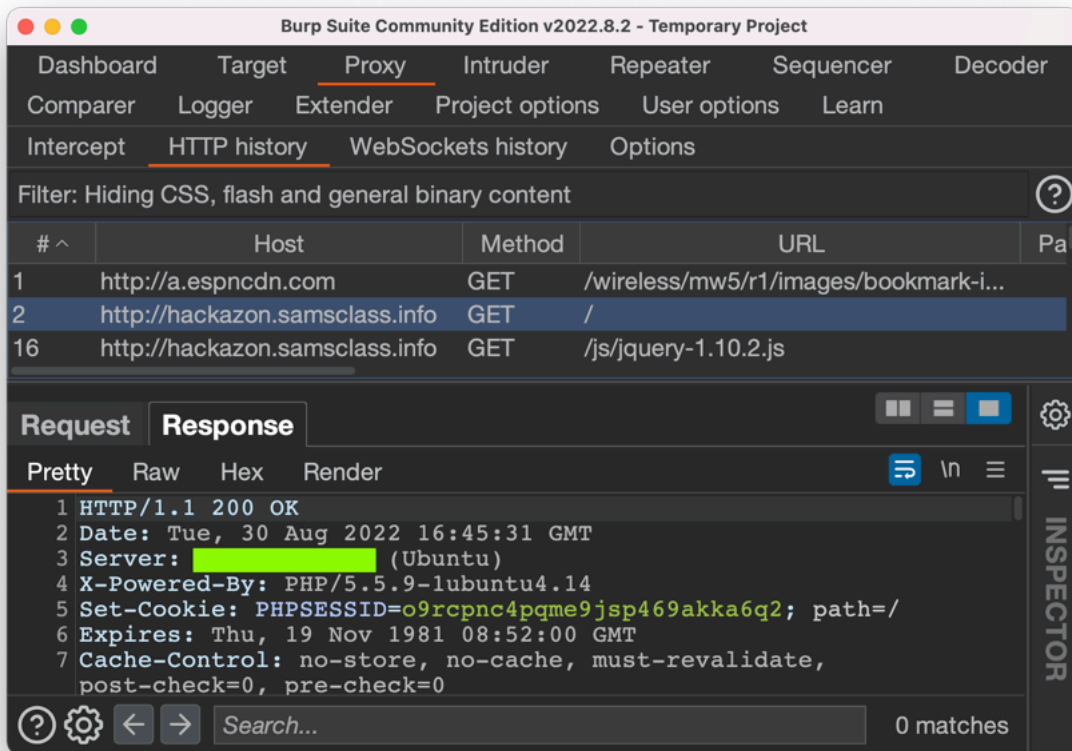
M 103c: Server (10 pts)

In Burp, on the **Proxy** tab, click the "HTTP history" sub-tab.

Scroll down and the GET request that loads **hackazon.samsclass.info** as shown below.

Click the GET request. In the lower left pane, click **Response**.

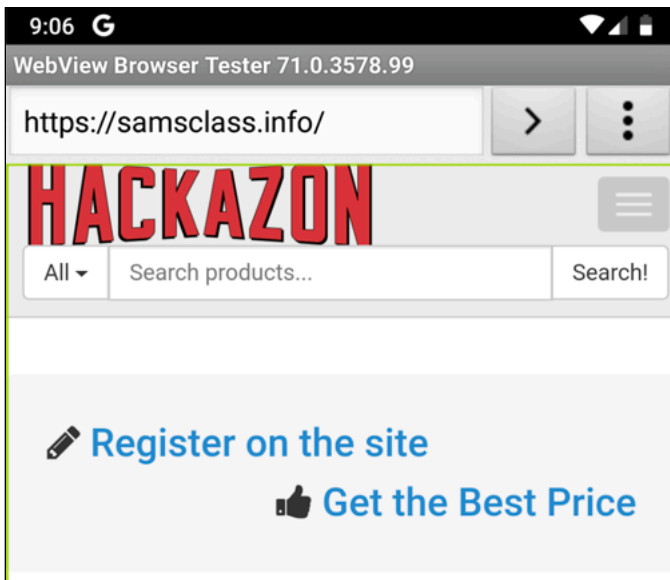
Find the text covered by a green box in the image below. That's the flag.



Opening a Secure Page

In the Android device, in the Browser, and go to

<https://samsclass.info> The browser does nothing, as shown below. It's a lousy browser, which is why we installed Chrome.



Opening a Secure Page in Chrome

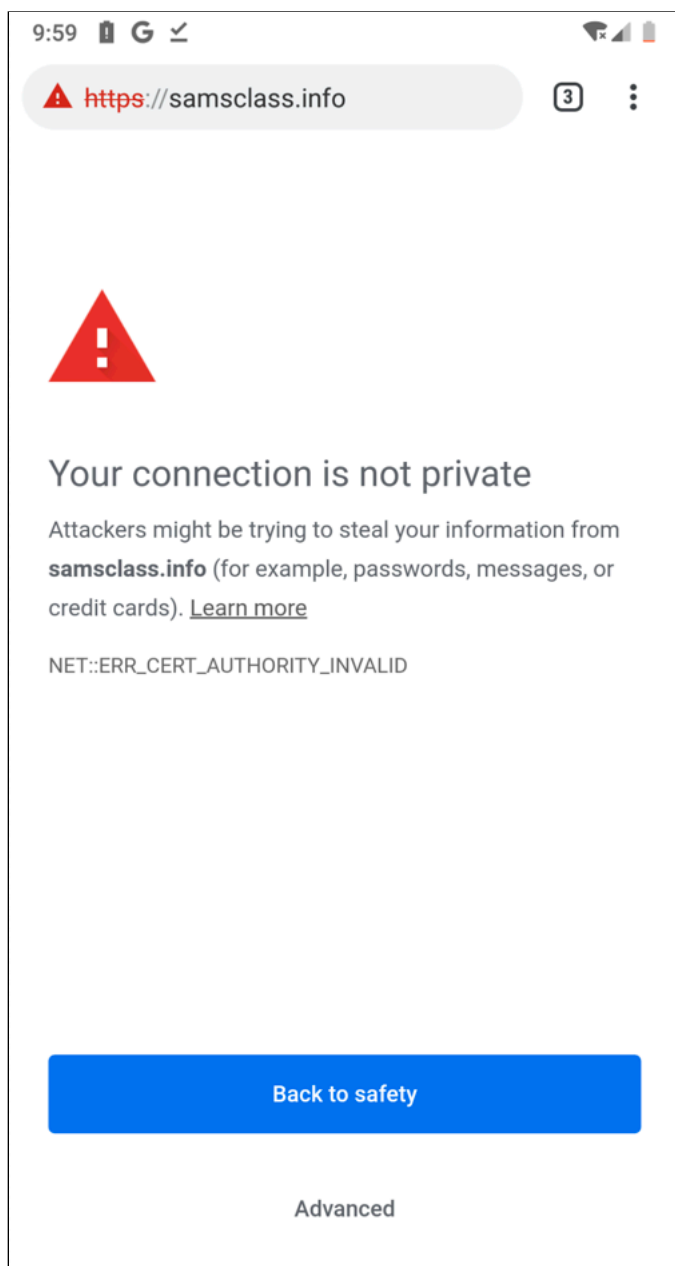
At the bottom center of the device, click the Home button. Open **Chrome**.

When you see the "Sign in to Chrome" page, click **"NO THANKS"**.

In Chrome, go to

<https://samsclass.info>

A warning message appears, saying "Your connection is not private", as shown below. Notice the specific error shown: **NET:ERR_CERT_AUTHORITY_INVALID**. This happens because Burp is performing a man-in-the-middle attack with a self-signed certificate.

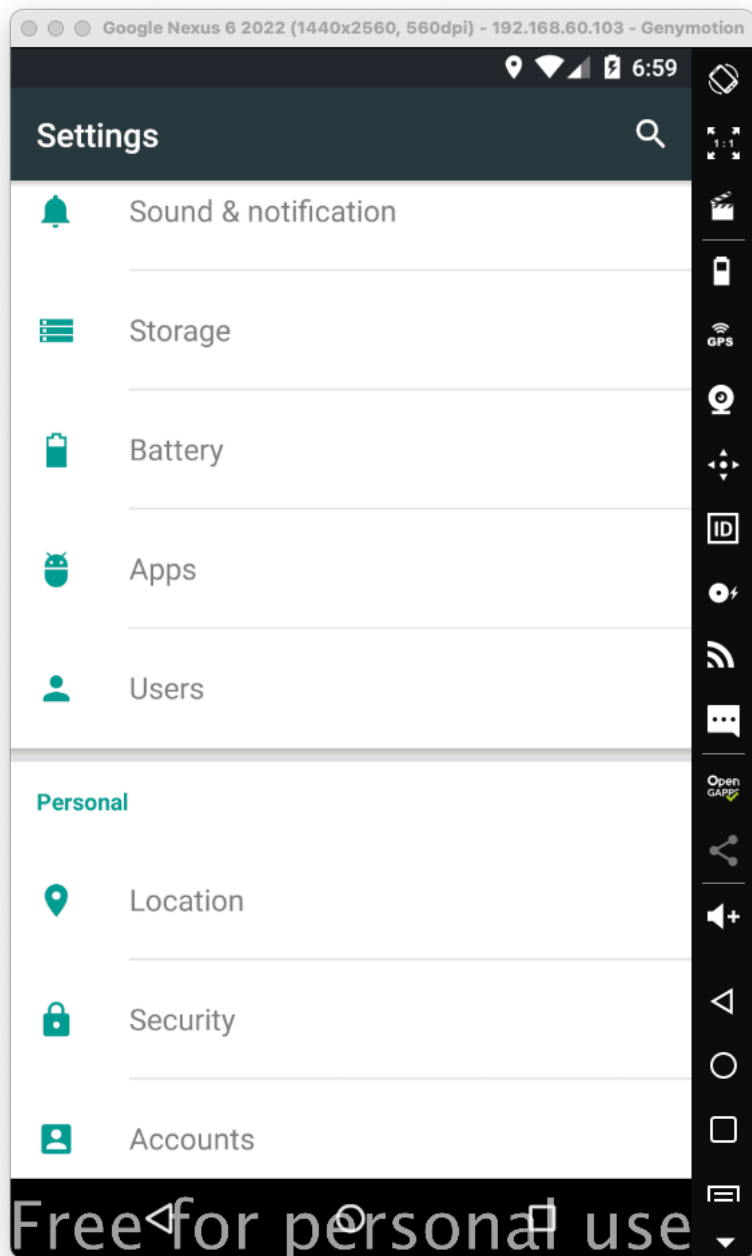


Setting a PIN

Android won't let us import a certificate until the device has a PIN configured, so we'll do that first.

At the bottom center of the device, click the Home button. Open **Settings**.

Click **Security**, as shown below.



In the Security screen, click "**Screen lock**".

In the "Choose screen lock" screen, click **PIN**.

Enter a simple PIN you can remember, such as **1234**, twice. Click **DONE**.

Exporting the PortSwigger CA Certificate from Burp

This is HTTPS working as it should, warning you that you do not have a secure connection to the end site. Burp is intercepting the traffic.

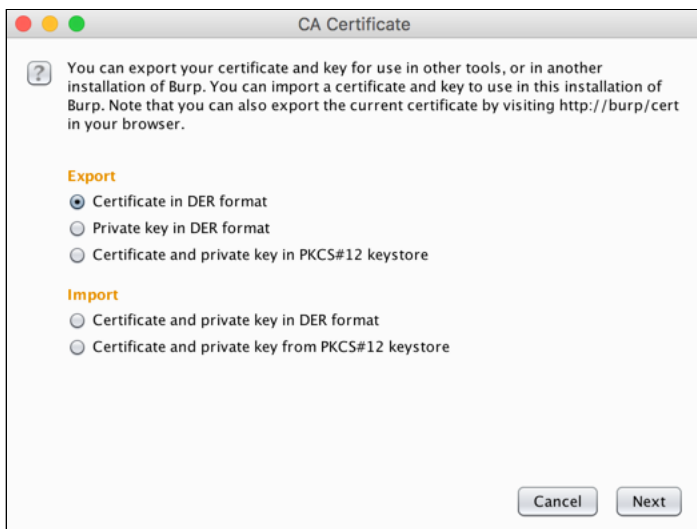
We want to add PortSwigger as a trusted certificate authority to get rid of these messages.

In Burp, click the **Proxy** tab.

Click the **Options** sub-tab.

Click the "**Import /export CA certificate...**" button.

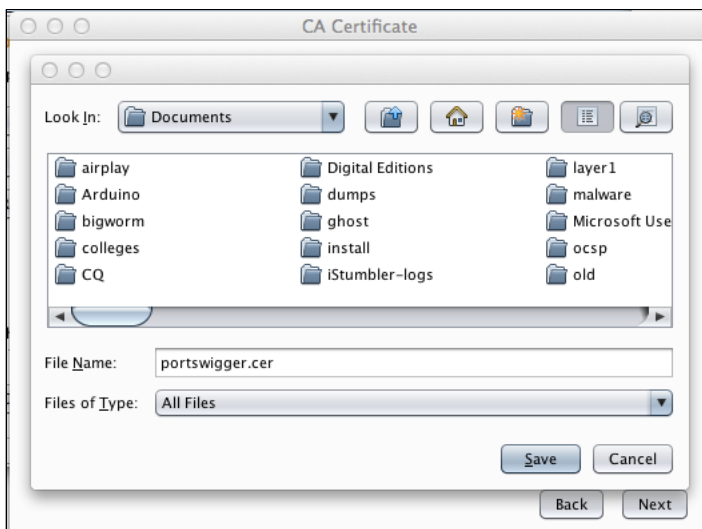
In the "CA Certificate" box, in the Export section, click the "**Certificate in DER format**" button, as shown below.



Click **Next**.

On the next page, click the "**Select file...**" button. Navigate to a folder you can find, such as your Desktop.

Give the file a name of **portswigger2022.cer**, as shown below.



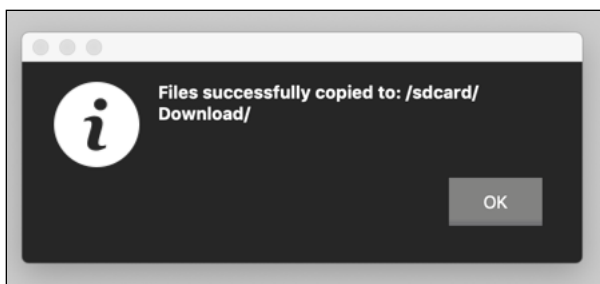
Click **Save**.

Click **Next**. Click **Close**.

Installing the PortSwigger CA Certificate into Android

Drag the **portswigger.cer** file from your host system and drop it on the Android home page.

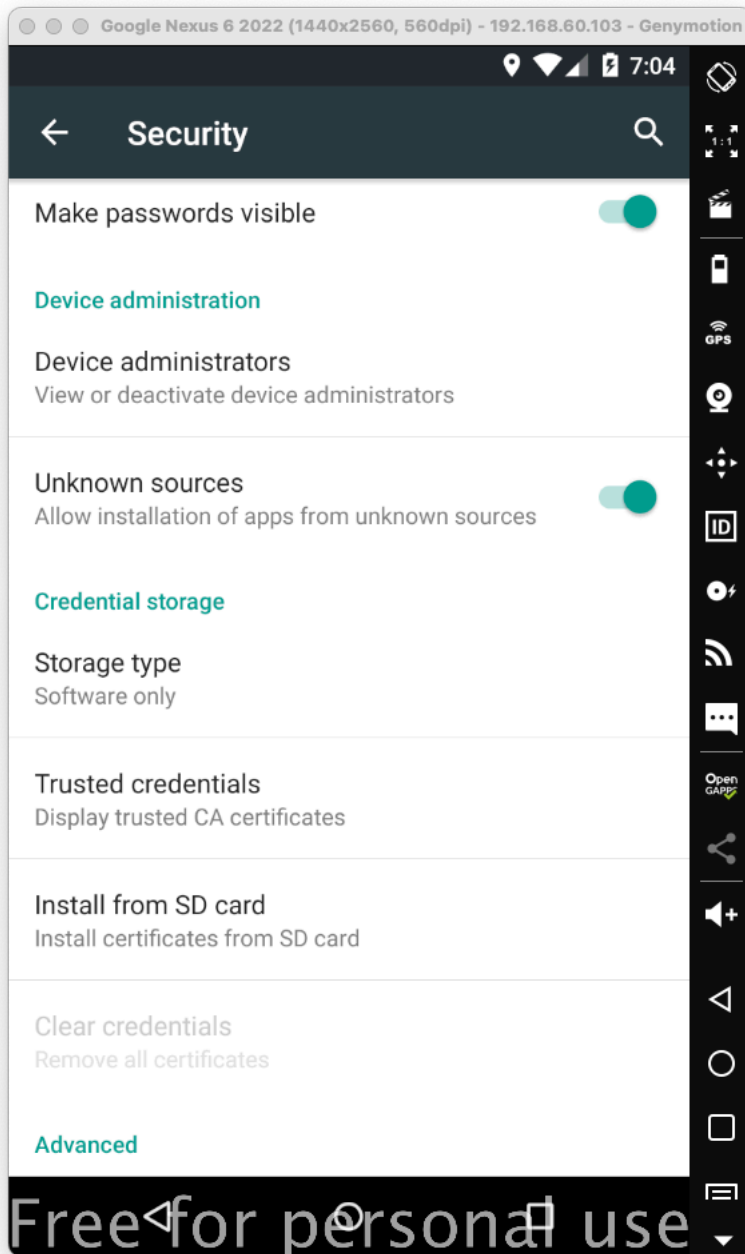
A message appears, saying "Files successfully copied to sdcard/Download", as shown below.



Click **OK**.

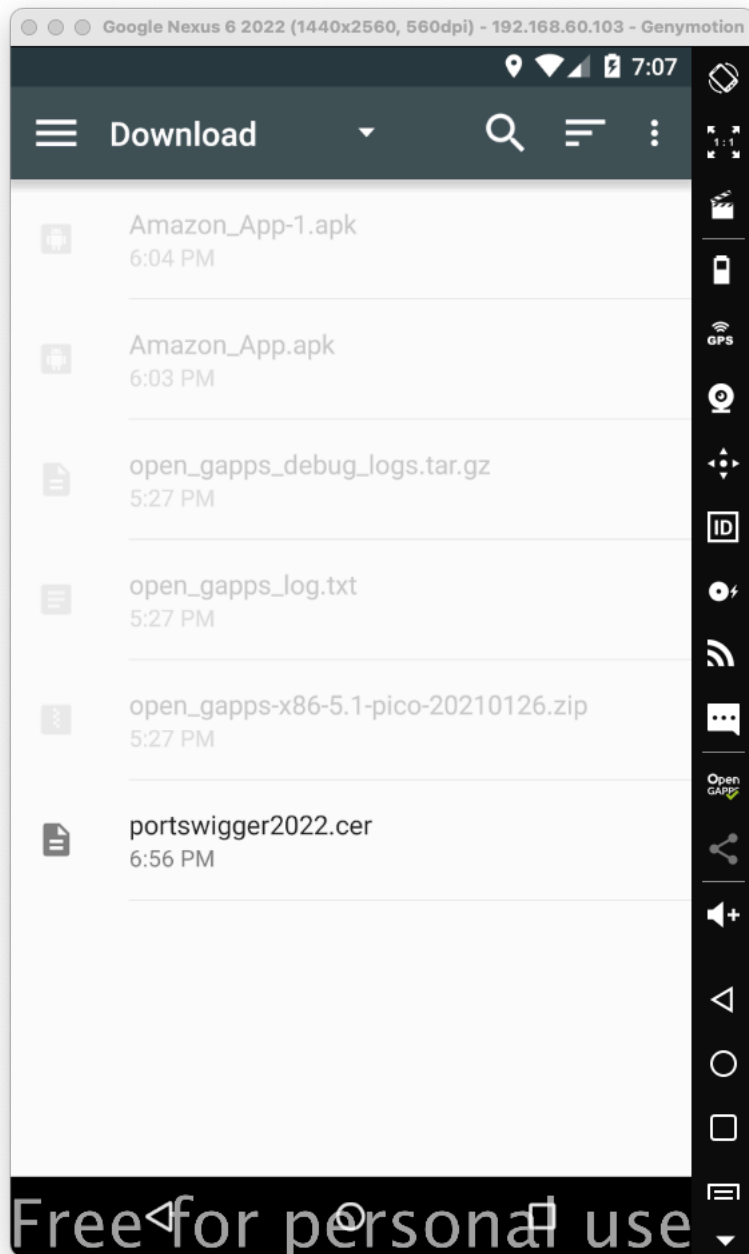
Importing the Portswigger Certificate

On your Android device, in Settings, on the Security page, click "**Install from SD card**", as shown below.



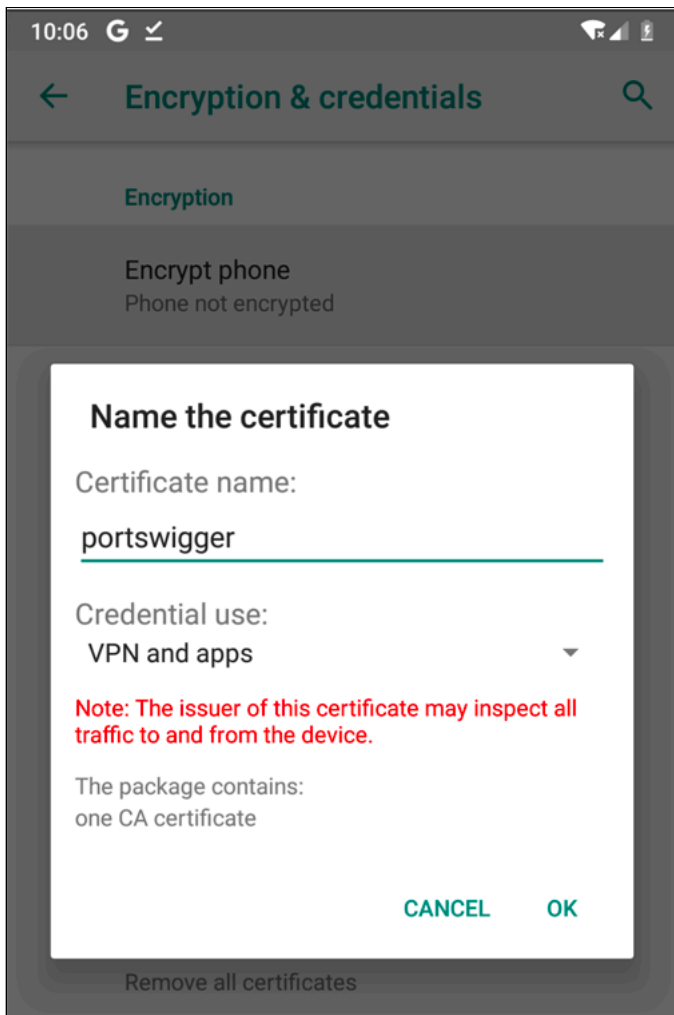
In the next screen, click "**Internal storage**". Click **Download**.

In the Downloads window, click **portswigger2022.cer**, as shown below.



Enter your PIN.

Enter a name of **portswigger**, as shown below, and click **OK**.



Opening a Secure Page Again

In Android, launch Chrome. Go to

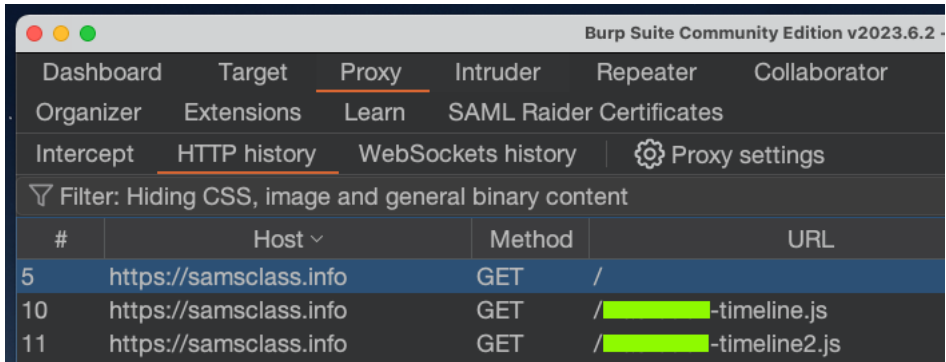
<https://samsclass.info> The page opens, as shown below.



Viewing HTTPS Requests in Burp

In Burp, on the **Proxy** tab, click the "HTTP history" sub-tab.

Find the line that shows the **https://samsclass.info** page loading, as shown below.



M 103d: Filename (10 pts)

Find the text covered by a green box in the image above. That's the flag.

Adjusting Android to Bypass the Proxy

While Burp is useful, most of the time you want to bypass it so you can get to Google Play.

From the Android home screen, click the circle at the bottom center.

Open **Settings**.

In Settings, click "**Network & internet**".

Click **Wi-Fi**.

Click **AndroidWiFi**.

Click **Advanced**.

In the "Network details" screen, at the top right, click the **Pencil** icon.

In the "Proxy" field, click the down-arrow.

Click **None**.

Then click **Save**.

Last modified 1-13-19

Warning added 1-23-19

Modified into a CTF 2-28-19

Reference to form for flag submission removed 2-4-2020

Note about Android v 5 added 2-6-21

Updated 8-22-22

Flag changed to M 103c 8-30-22

Second flag changed to M 103d on 2-8-24